LANCE : méthodes d'audit et architectures de preuve

Synthèse Codex à partir de trois revues spécialisées

Dernière révision : 2026-10-07 13:56 (Europe/Brussels, UTC+02:00)

Exploration et protocole proposé ; aucun gain expérimental établi

Résumé

Comment rendre l'approche LANCE plus intéressante scientifiquement et plus utile à un auditeur ? Trois agents ont examiné le pipeline, les méthodes d'audit défensif et les conditions d'une comparaison crédible. La piste prioritaire est une architecture qui relie chaque conclusion à une propriété précise, à des observations attribuées et à ses contre-preuves ou inconnus. Le modèle de langage intervient ensuite dans une explication citée ou une relecture bornée. L'évaluation proposée commence hors ligne, sur des dossiers identiques, avec une référence à règles forte. Le pipeline possède déjà plusieurs briques utiles ; l'étude recommande leur prolongement plutôt qu'une nouvelle orchestration complète. La copie de travail conflictuelle et l'absence de campagne interdisent toute conclusion sur un gain réel. Une équivalence avec les règles seules serait également un résultat utile.

Table des matières

1 Question et contribution envisagée **2**

2 Méthode et statut des preuves **2**

3 Ce que LANCE possède déjà **2**

4 Méthodes à comparer et choix proposé **3**

5 Architecture proposée : du journal à une conclusion bornée **4**

6 Expériences qui rendraient la contribution défendable **4**

7 Plan d'intégration proposé **5**

8 Discussion et limites **6**

9 Conclusion et prochaines étapes **6**

Références **6**

1 Question et contribution envisagée

LANCE conduit un audit de réseaux d'objets connectés, ou IoT, avec un modèle de langage, ou LLM. Les recherches précédentes posent déjà la comparaison entre **D1, automatisation conditionnelle sans LLM**, et **A1, politique adaptative avec LLM**, à outils et budgets comparables [4]. Ajouter des agents ou changer de modèle ne suffit donc pas à constituer une nouvelle contribution.

La question complémentaire proposée est : **à observations constantes, une organisation explicite des preuves réduit-elle les conclusions excessives et facilite-t-elle la vérification du rapport ?** Une seconde question examine la valeur marginale d'une relecture par LLM. La première porte sur le contrat de preuve ; la seconde sur l'interprétation. Une amélioration de rédaction ne prouve pas une meilleure détection réseau.

Une conclusion d'audit devrait rendre visibles quatre éléments : la propriété examinée, la portée dans laquelle elle est évaluée, les observations qui la soutiennent ou la contredisent, et les limites empêchant de conclure. Cette structure permet de discuter une conclusion plutôt que de comparer uniquement un nombre de vulnérabilités déclarées. Elle est ici une **proposition de recherche**, sans revendication d'originalité mondiale.

2 Méthode et statut des preuves

2.1 Trois revues complémentaires

Le travail du 7 octobre 2026 répartit trois tâches bornées entre agents : lecture statique du pipeline [1], revue ciblée de sources primaires [2], et protocole d'évaluation [3]. Le présent rapport en tire une décision de priorité. Les rapports spécialisés conservent les références détaillées, les passages consultés et leurs limites ; ils ne sont pas remplacés par cette synthèse.

Les index `research/README.md` et `docs/README.md`, les conventions du dépôt et les études existantes ont été consultés. La recherche bibliographique est ciblée et non systématique. Les sources retenues sont des publications d'origine ou des spécifications officielles. Aucun résultat publié n'a été reproduit et aucun classement de performances hétérogènes n'est construit.

2.2 État local et limites de lecture

Le commit de base est `a8dbeb9404f0cad960d61e42f02a1d70ca143a59`. La lecture porte aussi sur des modifications locales et des fichiers non versionnés. Des conflits non résolus affectent notamment la documentation des phases et le contrat des métriques. L'étude conserve cet état ; elle ne suppose ni que cette copie s'importe, ni qu'elle correspond au système déployé. Le manifeste `sources-locales.json` consigne chemins, empreintes et marqueurs de conflit des fichiers locaux concernés.

On distingue dans la suite : *fait de lecture statique*, *fait sourcé*, *hypothèse* et *proposition*. La compilation et la relecture des PDF valident leur présentation, pas les performances de LANCE. Aucune expérience réseau, campagne de benchmark ou modification du pipeline n'est réalisée pour cette étude.

3 Ce que LANCE possède déjà

La table de routage `src/agent/phases/registry.py` décrit six phases : graphe, reconnaissance, analyse, vérification, évaluation des accès et rapport. Il existe déjà un journal des appels, des références d'observations, un registre de candidats et des validations de livrables. Les profils full et compact adaptent le traitement dans cette organisation commune [1].

Le rapport final associe des fiches aux hypothèses et conserve les données factuelles dans un assemblage déterministe. Un diagnostic de référence vérifie certains liens d'identifiant et de destination ; sa source précise qu'il ne valide pas à lui seul la propriété de sécurité [5]. L'architecture de preuve proposée doit prolonger ces acquis, sans créer un évaluateur concurrent dans la rédaction du rapport.

Limite vérifiée. Le chargeur d'outils peut filtrer ou tronquer `stdout` avant le retour de l'outil `src/agent/tools/tool_loader.py`, lignes 228 à 235 ; le wrapper archive ce retour dans `src/agent/core/executor.py`, ligne 132. Dans ce chemin, une référence au journal ne garantit pas la conservation intégrale de la sortie native. Cette lecture n'établit pas que toutes les observations seraient incomplètes, ni qu'une preuve particulière serait invalide. Elle impose de déclarer les transformations et les limites de lecture [1].

Le socle existant rend donc plausible un premier essai hors ligne. Une réécriture intégrale du moteur aurait un coût élevé et ferait varier trop de facteurs pour attribuer un éventuel progrès.

4 Méthodes à comparer et choix proposé

La revue distingue sept familles de méthodes [2]. Le tableau 1 indique les usages retenus pour LANCE. Les priorités expriment un jugement d'intégration et de testabilité ; elles ne sont ni un score mesuré ni une estimation en jours.

Méthode	Apport attendu	Limite principale	Priorité
Provenance des observations	Relier source, transformation et conclusion	Un lien ne prouve pas la vérité de la propriété	1
Argumentation de preuve	Expliciter obligations, portée et contre-preuves	Les obligations doivent être définies et vérifiées	1
Comparaison différentielle	Comparer dossiers sain et fragile, puis avant et après correction	Contrôler les autres différences entre dossiers	2
Synthèse avec citations	Aider à retrouver les observations utiles	Une citation peut être hors sujet ou insuffisante	2
Relecture séparée	Rechercher incohérences et inconnus omis	Les lecteurs peuvent partager les mêmes erreurs	3
Matrice de capacités IoT	Relier le périmètre à des capacités documentées	Un audit réseau n'observe pas toutes les exigences	3
Applicabilité des avis	Relier inventaire fourni et avis constructeur	Version ou configuration manquante : rester indéterminé	3

Table 1 – Pistes défensives et ordre proposé. Les gains restent à mesurer.

Le modèle de provenance du World Wide Web Consortium (W3C) distingue données, activités et responsabilités dans leur production [7]. Nous en retenons une représentation minimale des transformations, sans imposer un serveur de graphe ou une ontologie complète. Les capacités du rapport NISTIR 8259A du National Institute of Standards and Technology constituent un point de départ pour préciser le périmètre IoT, adapté au contexte de l'organisation [8]. Leur association à une observation ne constitue pas une certification de conformité.

Choix recommandé : commencer par la provenance et les obligations de preuve ; construire ensuite des dossiers appariés ; ajouter une relecture sémantique seulement si sa valeur propre peut être isolée. Les travaux sur les arguments d'assurance, les capacités IoT, les politiques d'autorisation, les avis constructeur et la synthèse citée motivent les autres pistes dans la revue spécialisée, avec leurs versions et limites de lecture [2]. Ce choix ne reprend pas leurs systèmes complets et n'en transfère pas les performances à LANCE.

5 Architecture proposée : du journal à une conclusion bornée

La figure 1 représente un traitement de dossiers **déjà collectés**. Il ne choisit pas d'actions réseau. La validation locale reste propriétaire de l'acceptation technique ; le lecteur LLM propose une explication ou signale un doute, sans produire de nouvelle observation.

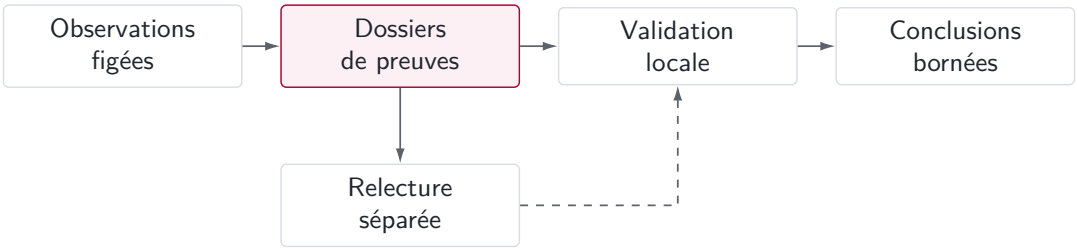


Figure 1 – Architecture proposée hors ligne. La flèche en pointillés transmet des remarques de relecture, pas une preuve supplémentaire.

Un dossier relie une déclaration à une **propriété**, à une cible et un service, à la ressource concernée, à l'identité ou au rôle pertinent et à un instant ou état. Il conserve les références, les transformations subies et les obligations de preuve satisfaites, manquantes ou contredites. Une obligation est une condition minimale pour étayer la propriété : par exemple, connaître l'identité et la ressource concernées pour juger une autorisation. Le premier format peut rester un fichier structuré exporté à côté du journal ; les artefacts d'origine restent la source.

La portée doit empêcher les généralisations abusives. Par exemple, un dossier de configuration fourni par le propriétaire indique qu'un rôle de supervision peut lire une mesure et que le rôle invité doit être refusé. Une observation de lecture réussie sans identité attestée ne suffit pas à conclure à un défaut d'autorisation. Une observation de refus sur la même ressource étaye seulement ce refus dans le contexte enregistré. Cet exemple est conceptuel et ne décrit aucune expérience réalisée.

Le verdict de propriété devrait distinguer *étayé*, *contredit* et *indéterminé*, avec les obligations concernées. L'applicabilité, la couverture de collecte et l'état d'exécution restent des champs distincts. Un échec technique n'est pas une contre-preuve. Une information absente n'est pas un contrôle sain. Une absence de défaut étayé n'établit pas la sécurité globale d'un appareil. Ces distinctions sont des exigences du prototype, pas une nouvelle version du contrat courant.

6 Expériences qui rendraient la contribution défendable

6.1 Comparaison principale et ablation du lecteur

Le protocole spécialisé [3] propose trois traitements, à mêmes observations et règles d'acceptation autant que possible :

— **E0, référence à règles forte** : dossier commun normalisé, branchements pertinents et références accessibles ;
— **E1, relations de preuve explicites** : même information, relations déclaration–observation–obligation et contradictions conservées ;
— **E2, E1 avec relecture sémantique LLM bornée** : remarques sur les mêmes preuves, sans action ni pouvoir autonome d'acceptation.

E1 contre E0 isole la structuration ; E2 contre E1 examine la relecture. Si E0 et E1 appliquent des règles sémantiquement équivalentes à la même information, leurs verdicts peuvent être identiques. Le bénéfice peut alors concerner l'attribution, la traçabilité ou l'inspection humaine. Ajouter simultanément de nouvelles règles et un graphe empêcherait d'attribuer le gain à la seule représentation.

Le corpus proposé associe cas positifs, cas proches sains ou corrigés, observations contradictoires, provenance ambiguë et données insuffisantes. Un pilote explore l'annotation et les coûts ; un jeu indépendant et gelé porte ensuite la comparaison. Les noms S20–S29 ne garantissent pas l'indépendance historique du test public [6].

6.2 Mesures et critères de décision

La mesure principale proposée est le taux d'attribution valide des références à la bonne cible, ressource, identité et période. Le taux de confirmations abusives, selon une référence indépendante, constitue un garde-fou. L'état réel de la propriété et le soutien disponible dans le dossier sont deux références distinctes : une propriété vraie mais insuffisamment documentée ne peut être déclarée étayée sur ce seul dossier. Il faut rapporter aussi la couverture de décision, les abstentions appropriées et les obligations satisfaites reconnues : ne jamais conclure pourrait sinon paraître artificiellement optimal. Le protocole donne les dénominateurs et les conditions où la mesure est indéfinie [3].

Les mesures secondaires portent sur la pertinence sémantique des références, les contradictions ignorées, les incohérences de portée et la consommation de tous les essais, y compris les échecs. Les familles, et non les seules répétitions, doivent structurer l'incertitude statistique. Les métriques actuelles du benchmark restent inchangées ; les métriques proposées complètent la recherche sans recalculer les scores historiques.

Une mesure du temps humain exige une tâche réelle de vérification, des rapports attribués dans un ordre contrôlé et une qualité finale évaluée. Des tokens réduits ou un rapport plus court ne démontrent pas un gain de travail humain. Les marges acceptables de qualité et de coût restent à fixer sur le développement avant le gel ; aucune valeur arbitraire n'est présentée comme validée.

7 Plan d'intégration proposé

Le tableau 2 précise les lots et leurs critères d'achèvement. Ces travaux sont proposés, non implémentés par la présente étude. Le coût relatif augmente surtout lorsque la collecte ou l'étude humaine doit changer.

Lot	Résultat concret	Validation attendue
0	Snapshot cohérent, contrat de preuve et périmètre gelés	Conflits résolus par leur travail propriétaire ; version exécutable identifiée
1	Export hors ligne des dossiers avec provenance et obligations	Références résolues ; transformations explicites ; doublons et inconnus conservés
2	Corpus apparié et traitements E0/E1	Annotation indépendante ; information commune ; erreurs et coûts conservés
3	Relecture E2 et rapport cité	Apport mesuré sans nouvelles observations ; refus d'une citation non pertinente
4	Extension à nouvelles familles puis étude humaine	Gel avant test ; indépendance documentée ; qualité et temps évalués séparément

Table 2 – Ordre proposé ; le lot suivant dépend des preuves obtenues dans le précédent.

Les propriétaires à examiner sont les modules de preuves sous `src/agent/evidence/`, le registre de candidats sous `src/agent/phases/analysis/`, la traçabilité du rapport sous `src/agent/phases/report/`, et les mesures sous `src/benchmark/`. Leur interface doit être définie après gel du code, en réutilisant les responsabilités existantes. Les données évaluateur et les observations publiques restent séparées. Les notes de recherche décrivent les propositions ; `docs/` accueillera seulement les comportements retenus et vérifiés.

8 Discussion et limites

Le risque principal est de déplacer le problème vers des obligations de preuve mal définies : un graphe bien formé peut porter une conclusion fausse. Les références, l'intégrité du stockage et la pertinence sémantique sont trois questions différentes. Un hash aide à retrouver un artefact ; il n'authentifie pas à lui seul sa provenance distante.

Un second lecteur n'est indépendant que par les informations, règles et conditions effectivement séparées. Un même modèle relisant son propre texte peut reproduire ses erreurs ; multiplier les lecteurs peut aussi augmenter le coût et les désaccords. Les remarques doivent être confrontées aux observations, pas tranchées par un vote textuel.

Le premier corpus restera probablement simulé et dépendant des familles du benchmark. L'applicabilité aux appareils physiques, aux exigences organisationnelles et à des états temporels incomplets demeure à établir. Les travaux publiés et les normes étudiées orientent le protocole ; ils n'attestent pas une efficacité du système proposé.

9 Conclusion et prochaines étapes

La contribution la plus défendable consiste à évaluer **la qualité des conclusions et leur vérifiabilité**, plutôt qu'à présenter le nombre d'agents comme une amélioration. L'ordre recommandé est : provenance et obligations, comparaison hors ligne de dossiers appariés, puis relecture LLM et mesure humaine si les premiers résultats le justifient.

Le prochain livrable expérimental devrait être un petit corpus annoté et un comparateur E0/E1 gelé. Une absence de gain technique peut conduire à conserver les règles seules et à réserver le modèle à l'explication. Aucune architecture nouvelle n'est adoptée et aucun gain n'est annoncé à ce stade.

Références

[1] Agent `pipeline_review`, *LANCE : architecture du pipeline et méthodes de preuve*, 7 octobre 2026. Rapport spécialisé ; source `pipeline.tex`. Lecture statique de la copie locale, sans exécution.

[2] Agent `methods_review`, *Méthodes d'audit IoT fondées sur les preuves : sept familles pour rendre LANCE plus utile à l'auditeur*, 7 octobre 2026. Rapport spécialisé ; source `methodes.tex`. Sources primaires, versions et profondeur de lecture indiquées dans le rapport ; aucune reproduction.

[3] Agent `evaluation_review`, *Comparer des méthodes de gestion des preuves pour LANCE : protocole hors ligne à observations communes*, 7 octobre 2026. Protocole proposé ; source `protocole.tex`. Aucun résultat expérimental.

[4] LANCE, *Apport de l'agent face à l'automatisation*, étude commencée le 27 septembre 2026. `research/2026-09-27-agent-vs-automation/README.md` et `protocol.md`. Lecture du protocole existant, pas de campagne reproduite.

[5] LANCE, *Rapport rédigé par sections* et *Livrables : un dossier explicite par run*, copie locale consultée le 7 octobre 2026. `docs/architecture/report-writing.md`, `run-artifacts.md` ; `src/agent/phases/report/traceability.py`. Lecture ciblée, sans import de l'application.

[6] LANCE, *V1 : scénarios et données*, copie locale consultée le 7 octobre 2026. `docs/benchmark/v1/scenarios.md`. L'indépendance historique du test y est signalée comme non vérifiée.

[7] P. Groth et L. Moreau (dir.), W3C, *PROV-Overview*, Working Group Note du 30 avril 2013. https://www.w3.org/TR/2013/NOTE-prov-overview-20130430/. Introduction et feuille de route consultées le 7 octobre 2026 ; vue non normative, sans validation d'une implémentation PROV.

[8] M. Fagan et al., NIST, *IoT Device Cybersecurity Capability Core Baseline*, NISTIR 8259A, mai 2020. https://doi.org/10.6028/NIST.IR.8259A. Notice officielle, introduction et début de la section 2 consultés le 7 octobre 2026 ; aucune évaluation de conformité complète.